# 信息安全测评与风险评估

6.1 单项测评结论判定

授课教师：张玉



# 目录

CONTENTS


01 案例导入——“相同的证据，不同的结论”

02 学习目标

03 从现场测评到测评结论——数据加工链条

04 单项测评结论的定义

# 案例导入——“相同的证据，不同的结论”

- **引入问题：一堆测评记录表摆在你面前，怎么判断这个系统“过没过”？**

| 序号 | 测评证据 | 测评师A判断 | 测评师B判断 |
| --- | --- | --- | --- |
| 1 | login.defs中PASS_MIN_LEN=6 | 不符合（应8位） | 部分符合（长度不足） |
| 2 | 防火墙有“允许any any” | 不符合（违最小权限） | 不符合（同上） |
| 3 | 机房门禁记录不完整 | 部分符合 | 不符合（控制失效） |

**Q1**

同份证据，为何判断不同？

**Q2**

什么是“优势证据”？怎判可信？

**Q3**

标准不一，报告还能客观吗？



**结论：**单项判定是编制的**“第一粒扣子”**，必须掌握统一判定方法。

# 学习目标

通过本课学习，你将能够：

01 理解 单项测评结论在等保测评报告中的核心地位

02 掌握 单项测评结论的四种判定结果（符合/部分符合/不符合/不适用）及其判定标准

03 掌握 “优势证据”法的基本原理与应用

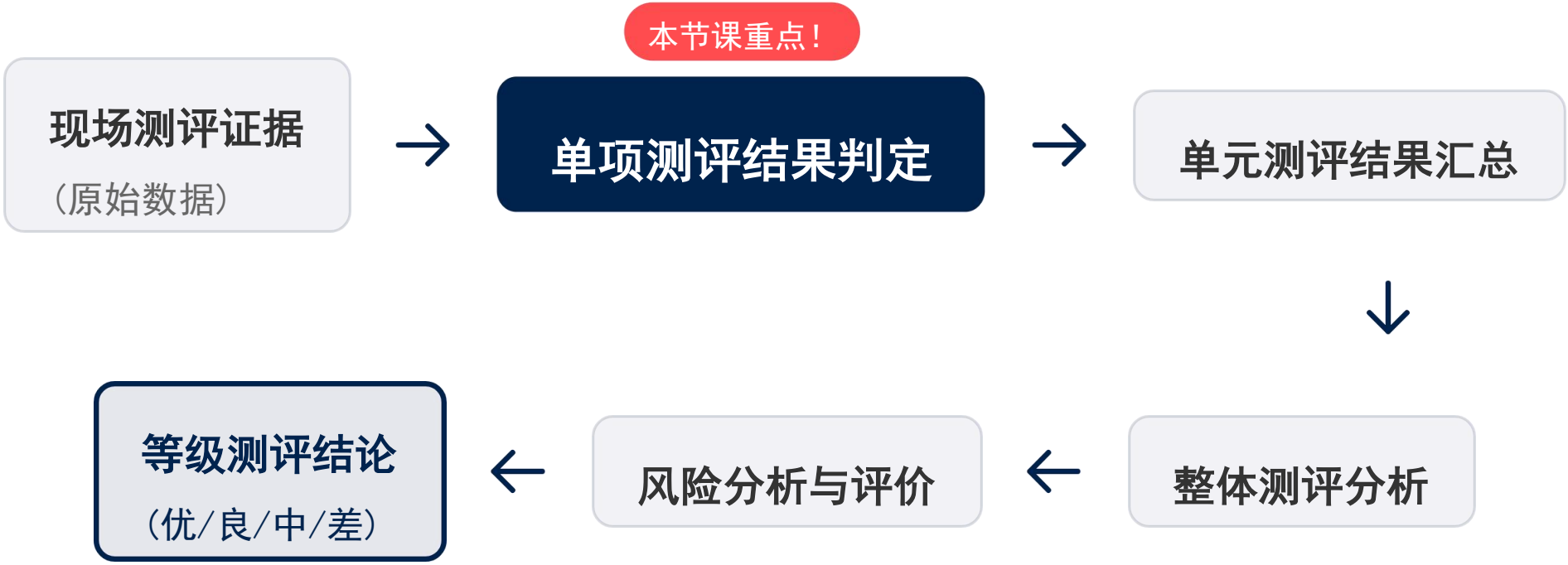
04 能够 根据测评证据准确判定单项测评结论

05 理解 单项测评结论与单元测评结论、整体测评结论的逻辑关系

06 具备 客观、公正、严谨的职业判断能力

# 从现场测评到测评结论——数据加工链条

测评结论的生成是一个“逐级加工”的过程。




**关键认识：**单项测评结论是后续所有结论的“地基”——地基歪了，整栋楼都会歪。

# 单项测评结论的定义

**根据GB/T 28448-2019《信息安全技术 网络安全等级保护测评要求》**

| | |
|---|---|
| 01定义 | 单项测评结果判定，是“针对等级测评指标中的单个测评项，结合具体测评对象，客观、准确地分析测评证据，形成初步单项测评结果”。 |
| 02输入 | 技术安全和管理安全的单项测评结果记录、测评指导书 |
| 03输出 | 测评报告的单元测评结果记录部分 |
| 04核心作用 | 单项测评结果是形成单元测评结论、整体测评结论和等级测评结论的基础 |

**关键点：单项测评结论是对“一个测评项”在“一个测评对象”上的表现做出的判断。**

## 四种判定结果

| 判定结果 | 符号 | 含义 | 适用场景 |
| --- | --- | --- | --- |
| **符合** | ☑ | 测评证据表明所有要求内容与预期测评结果一致 | 系统完全满足标准要求 |
| **部分符合** | ⚠ | 测评证据表明部分要求内容与预期测评结果一致 | 系统部分满足，有差距但非完全缺失 |
| **不符合** | ✗ | 测评证据表明所有要求内容与预期测评结果不一致 | 系统完全不满足标准要求 |
| **不适用** | N/A | 该测评项所对抗的威胁在系统中不存在 | 系统不涉及该项技术或管理领域 |

# 四项判定原则详解

## 原则1：判断威胁是否存在

分析测评项对抗的威胁在被测系统中是否存在，不存在则标为不适用。

**举例：系统无无线网络 → “无线接入控制”标为“不适用”**

## 原则2：逐项分析要求内容

分析单个测评项是否有多方面的要求内容，针对每一方面进行判断。

**举例：身份鉴别含：①唯一性 ②复杂度 ③定期更换 → 需逐项检查**

## 原则3：使用“优势证据”法

从证据中选择出“优势证据”，并与预期结果相比较。

**物理安全：**实地察看 > 文档 > 访谈
**技术安全：**工具测试 > 配置 > 访谈
**管理安全：**需根据实际情况分析确定

## 原则4：综合判定

所有要求与预期一致 → **符合**
所有要求与预期不一致 → **不符合**
否则 → **部分符合**

# “优势证据”法详解（15分钟）

## 核心概念

“优势证据”是指在得到的多个测评证据中，那个或者那些对于单个要求项的符合性判定**更具有证明力、说服力**的测评证据。

## 为什么需要“优势证据”法？

由于不同测评人员对优势证据的理解可能不同，选择的证据就不同，导致结果产生差异。为避免这种情况，**必须统一使用**该方法。

| 测评领域 | 优势证据层级（从高到低） | 具体举例及不同证据对比 | 应采信的证据 |
| --- | --- | --- | --- |
| **物理安全** | **实地察看**＞文档审查＞访谈 | **机房温湿度控制**<br>访谈证据：管理员说温湿度正常<br>配置检查证据：查看温湿度记录<br>工具测试证据：实地察看温湿度计 | **实地察看** |

# 四种判定结果的判定标准（核心对照表）

| 判定结果 | 判定条件 | 举例 |
| --- | --- | --- |
| 符合 | 所有要求内容与预期完全一致 | 密码长度≥8位，复杂度要求全部满足 |
| 部分符合 | 部分要求内容一致，部分不一致 | 密码长度6位（要求≥8），但启用了复杂度 |
| 不符合 | 所有要求内容与预期均不一致 | 未启用密码策略，空口令账户存在 |
| 不适用 | 该测评项对抗的威胁不存在 | 系统无无线网络，无线接入控制指标不适用 |

# 判定常见错误类型

**错误类型：将“部分符合”误判为“符合”**

**错误表现：**“密码策略基本满足，只是长度稍短”——应判为“部分符合”

**正确做法：**任何一项要求不满足，就不能判“符合”

**错误类型：“不适用”理由不充分**

**错误表现：**“系统没有这个要求”——未说明威胁是否存在

**正确做法：**必须说明“该测评项所对抗的威胁在系统中不存在”

**错误类型：未逐子项判定**

**错误表现：**一项指标含多个子项，未逐子项分析

**正确做法：**拆分到每个子项分别判定

**错误类型：过度依赖访谈证据**

**错误表现：**“管理员说配置了”——没有核查确认

**正确做法：**技术安全以工具测试/配置检查为优势证据

**思政融入：**判定错误往往不是能力问题，而是态度问题——不认真、不严谨、不负责。每一次判定都是职业操守的“试金石”。

# 判定过程演示（15分钟）

素材4：教师演示用——快速判定参考

## 演示案例1：服务器身份鉴别

| 测评项 | 要求内容 | 测评证据 | 优势证据 | 判定结果 |
| --- | --- | --- | --- | --- |
| 8.1.4.1 a) | ①标识唯一 ②复杂要求 ③定期更换<br><br>①访谈：用户唯一②核查：密码长度6③核查：无有效期 | 配置检查 | 部分符合 | |

**判定说明：**a）复杂度不够且唯一性未完全验证；b）有失败处理但无超时。均“部分符合”。

## 演示案例2：防火墙访问控制

| | | | | |
| --- | --- | --- | --- | --- |
| 8.1.3.2 b) | 删除多余或无效规则 | 核查：5条未使用策略 | 配置检查 | 不符合 |

**判定说明：**存多余策略，未执行规则最小化，判“不符合”。

**单项结论** → **单元结论** → **整体结论**

单项测评结论是“原材料”，单元测评结论是“半成品”，整体测评结论是“成品”。

| | |
|---|---|
| **单项测评结论** | **定义：**单个测评项在单个测评对象上的表现<br>**形成方法：**根据“优势证据”法判定（本课重点） |
| **单元测评结论** | **定义：**多个测评对象在同一个测评单元上的汇总表现<br>**形成方法：**汇总单项结论：全部符合→符合；全部不符合→不符合；部分符合/不符合→部分符合；全部不适用→不适用 |
| **整体测评结论** | **定义：**系统的整体安全状况<br>**形成方法：**从控制间、层面间、区域间综合分析 |

**单元测评结果判定原则：**

- 所有适用测评项的单项结果均为符合 → 符合
- 所有适用测评项的单项结果均为不符合 → 不符合
- 所有测评项均为不适用 → 不适用
- 适用项的单项结果不全为符合或不符合（含部分符合） → 部分符合

# 实践任务1——判定练习（20分钟）

| | |
|---|---|
| 任务名称 | 单项测评结论判定练习<br>素材1：单项判定练习卡（10个场景） |
| 任务场景 | 教师提供10个测评项的模拟测评证据（见素材1：单项判定练习卡） |
| 任务内容 | ① 阅读每个测评项的测评证据<br>② 识别“优势证据”<br>③ 逐项判定（符合/部分符合/不符合/不适用）<br>④ 填写判定依据和理由 |

# 实践任务1——判定要点

## 判定时要问自己三个问题：

- 这个测评项对抗的威胁在系统中存在吗？（决定是否“不适用”）
- 这个测评项有几个要求内容？（拆分到子项）
- 哪个证据最可信？（优势证据）（工具测试/配置检查/实地察看 > 访谈）

## 特别提醒：

- **不要**因为“大部分满足”就判“符合”
- **不要**因为“有一点不足”就判“不符合”
- 管理安全的判定要结合实际情况，不能只看文档“有没有”

# 常见判定场景对照表

| 场景 | 证据情况 | 判定结果 | 理由 |
| --- | --- | --- | --- |
| 密码长度≥8，启用复杂度，定期更换 | 全部满足 | **符合** | 所有要求一致 |
| 密码长度≥8，但未启用复杂度 | 部分满足 | **部分符合** | 部分要求一致 |
| 未配置密码策略，使用默认密码 | 完全不满足 | **不符合** | 所有要求不一致 |
| 系统无无线功能，无线接入控制 | 威胁不存在 | 不适用 | 威胁不存在 |
| 制度有“应做”，但无执行记录 | 有制度无执行 | **部分符合** | 文档满足，执行不满足 |

# 单项判定与等保得分的关系

等保2.0测评结论分为"优/良/中/差"四级，所有结论均建立在单项判定的基础之上

**综合得分计算公式**

$$S = 技术得分 \times 50\% + 管理得分 \times 50\%$$

默认技术与管理各占50%；关注系数由等保工作管理部门统一发布，可根据政策侧重调整两者占比

## ① 单项判定结果计分

| 判定结果 | 得分 | 说明 |
| --- | --- | --- |
| 符合 | 1 分 | 完全满足测评要求 |
| 部分符合 | 0.5 分 | 部分满足，存在不足 |
| 不符合 / 不适用 | 0 分 | 不适用项不计入总分 |

## ② 测评项重要性权重

| 测评项等级 | 权重系数 | 不符合扣分倍数 |
| --- | --- | --- |
| 一般测评项 | 0.4 | 扣 1 倍基准分 |
| 重要测评项 | 0.7 | 扣 2 倍基准分 |
| 关键测评项 | 1.0 | 扣 3 倍基准分 |

维度得分 = Σ(各测评项得分 × 该项权重) ÷ Σ(所有适用项权重) × 100 ｜ 关键项不符合将大幅拉低总分

## ③ 测评结论分级（分数 + 风险双重判定）

**优**

综合得分 ≥ 90 分

且不存在中、高等级安全风险

**良**

综合得分 ≥ 80 分

且不存在高等级安全风险

**中**

综合得分 ≥ 70 分

且不存在高等级安全风险（及格线）

**差**

综合得分 < 70 分

或存在高等级安全风险（不通过）

# 思政融入——判定中的职业道德

## 三个关键词：

### 客观

- 判定依据证据，非感觉
- 优势证据法保一致性

### 公正

- 不因客户关系“放水”
- 不因个人喜好“从严”

### 负责

- “符合”代表系统安全
- “不符合”影响整改

**一句话：单项测评结论判定的准确率，就是测评师职业操守的“及格线”。**

# 知识点回顾（5分钟）

**本课核心知识**

**01 定义与定位**

**定义：**对单个测评项在单个对象上的判定
**定位：**测评报告结论的“地基”

**02 判定结果**

- 符合（一致）
- 部分符合（部分一致）
- 不符合（不一致）
- 不适用（无威胁）

**03 优势证据法**

**物理安全：**察看 > 文档 > 访谈
**技术安全：**工具 > 配置 > 访谈

**04 判定流程**

判断威胁 → 拆解内容 → 选证据 → 判定

**05 上层结论关系**

单项 → 单元 → 整体 → 等级测评

# 课后作业

**必做**

完成《单项测评判定练习表》（10个场景），提交至学习通平台

**必做**

完成项目6.1在线测试（选择题+判断题，共20题）

**必做**

完成作业：06.1 单项测评结论判定

素材5：课后作业——单项判定练习

**预习**

预习活动6.2“系统整体测评结论形成”相关内容

# 下节课预告

## 活动6.2：系统整体测评结论形成

### 预告内容

- 如何汇总单项和单元测评结论
- 如何形成系统整体测评结论
- 风险趋势判断方法
- 整体结论的撰写规范

### 课前准备

- 复习本课的单项判定方法
- 准备前序项目的测评记录数据

*注：请同学们提前做好准备，以便下节课高效学习。*

# 感谢观看

